



ESTG — Guelmim

Département RIS

Encadrant académique :

Pr. Tarek Ait Baha

Encadrants professionnels :

Mr. A. Oubousseksou

Ms. S. Boukha

CRI-HR-Secure

Secure Design and Deployment of an HR Module
Integrated into an ERP System

The Case of CRI Guelmim-Oued Noun

Étudiant : Abderrahmane Aroussi

Période :

Avril – Juin 2026

Année Académique :

2025 – 2026

Jury : Pr. Amine Bouaouda — Pr. Tarek Ait Baha

Table of Contents

01

Organisational Context

CRI Guelmim & identified HR gaps

02

Project Scope & Architecture

Three-tier stack, Docker, VirtualBox

03

Security Hardening

HTTPS · RBAC · Fail2Ban · Auditd · Netdata

04

Validation & Results

SQLmap, attack simulation, performance

05

Limitations & Future Work

Engineering trade-offs and roadmap

06

Conclusion

Summary of contributions

01 | Organisational Context

CRI Guelmim-Oued Noun

- Public institution founded October 2002
- ~20 employees across departments
- Simplifies business creation & investment promotion
- Single point of contact (Guichet Unique)
- Manages Regional Unified Investment Commission

Current HR Gaps

Slow processing

Leave requests take days to reach approval

No centralisation

Data fragmented across paper & Excel files

No traceability

Zero audit trail for approvals or access

Data exposure

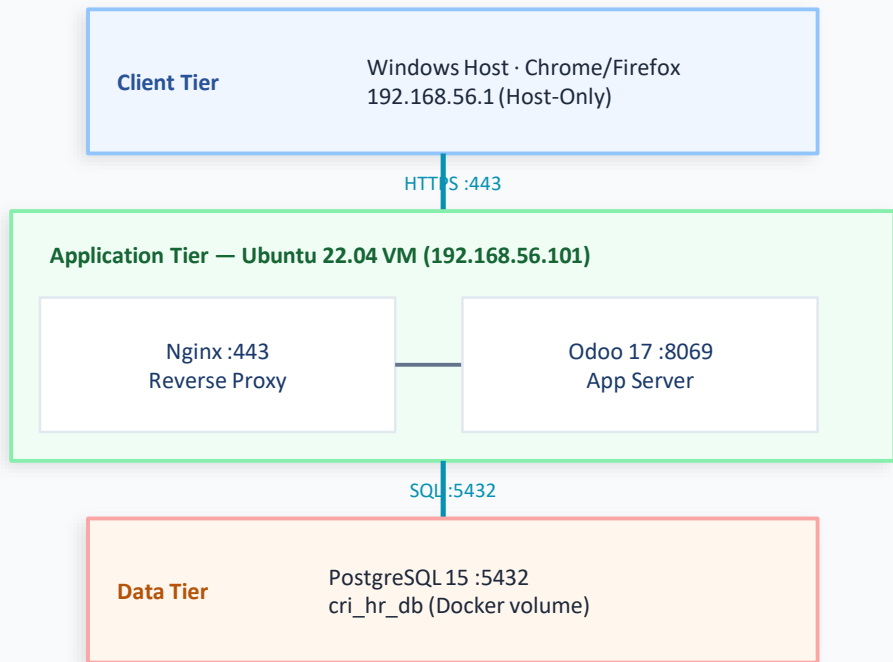
Sensitive HR data accessible to anyone physically

02 | Project Scope & Architecture

Technical Stack

ERP Platform	Odoo 17 Community
Database	PostgreSQL 15
Containers	Docker + Compose
Reverse Proxy	Nginx (Alpine)
Virtualisation	VirtualBox + Ubuntu 22.04 LTS
Certificates	OpenSSL 3.x — RSA-4096

3-Tier Architecture



Network: VirtualBox Host-Only 192.168.56.0/24 | No internet access

The prototype was deployed on a virtual machine · a standard practice for academic int

03 | Defence-in-Depth Security Architecture

HTTPS / TLS

Nginx reverse proxy, RSA-4096 self-signed cert
All traffic encrypted on port 443

RBAC

3 roles: Admin · HR Officer · Employee
Least-privilege access verified by negative testing

Fail2Ban

IPS on login endpoint — 5 attempts / 300s
Auto-bans offending IP via iptables DROP rule

Auditd

File-integrity monitoring on nginx.conf, docker-compose.yml
Structured audit log for compliance & forensics

Netdata

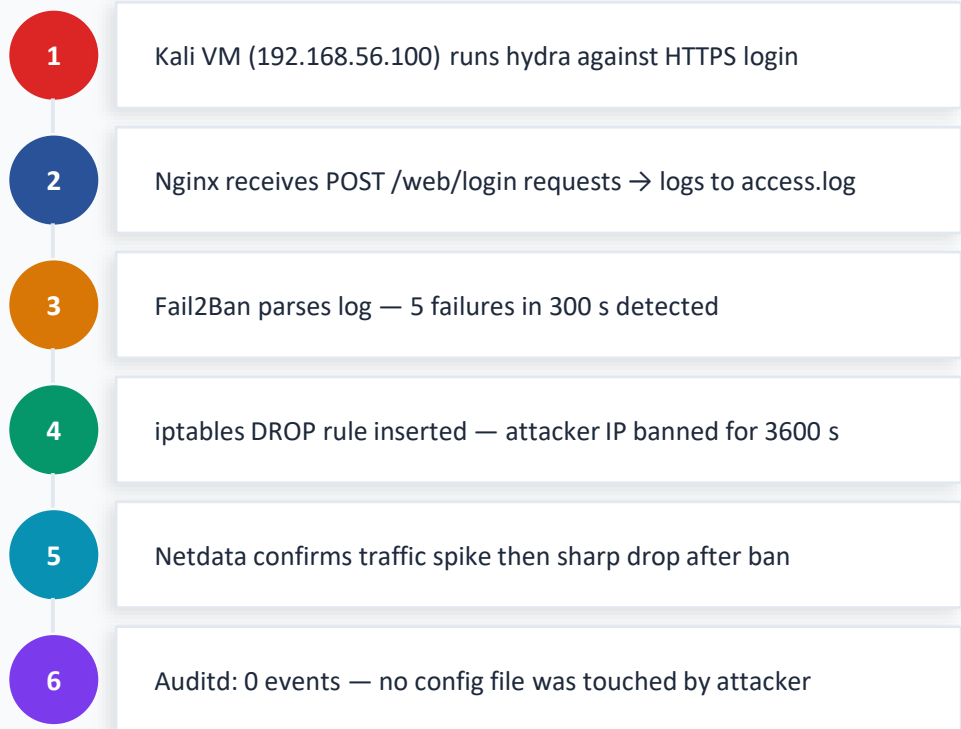
Real-time system observability — 4,500+ metrics/s
CPU, RAM, network traffic visualised live

SQL-Injection Audit

SQLmap — 432 tests, 0 injectable parameters
Odoo 17 ORM correctly parameterises all queries

04 | Validation & Results

Brute-Force Attack Simulation



Security Validation Results

Control	Outcome
Transport Encryption	✓ HTTPS verified, 0 clear-text
RBAC (3 roles)	✓ All boundaries confirmed
SQL Injection	✓ 432 tests — 0 findings
Brute-Force	✓ Ban after 5 attempts
File Integrity	✓ 0 spurious audit events
Monitoring	✓ Attack spike detected live
⚡ Load test (Apache Bench): Mean 0.325 s · 100 req · Concurrency 10 · 0 failures	

05 | Limitations & Future Work

Current Limitations

Self-signed TLS

Suitable for validation; production would require a CA-signed certificate (e.g., Let's Encrypt).

VM-only deployment

The Host-Only network is appropriate for an academic prototype; production would add firewall, DMZ, and VPN.

Lightweight tooling (no full SIEM)

Given the available resources (4.5 GB RAM), we selected Fail2Ban, Auditd, and Netdata - a conscious engineering trade-off for stability and transparency.

No automated backup

Not implemented in the prototype; production would require scheduled pg_dump.

Future Work Roadmap

1

Let's Encrypt CA-signed certificate

2

Deploy on hardened CRI server (DMZ + VPN)

3

Web Application Firewall — ModSecurity / CrowdSec

4

LDAP / Active Directory single sign-on

5

Two-Factor Authentication (TOTP) for privileged accounts

6

Automated nightly PostgreSQL backups



06 | Conclusion

7

Security layers

432

SQLmap tests — 0 findings

6

Weeks delivery

Key Contributions

Proof of concept for CRI

Fully functional secure HR prototype deployable within the constraints of an academic internship (virtualised environment) · one Ubuntu VM, three Docker containers

Defence-in-Depth Architecture

Seven independent security controls validated through penetration testing and controlled attack simulation.

RIS Competency Demonstration

Network isolation (VirtualBox Host-Only), system security hardening, Linux server administration applied to a real problem.

Reusable Baseline

All configuration files and security controls documented, providing a solid foundation for future production rollout.

Thank you — Questions Welcome